A46. A network team has installed new access points to support an application launch. In less than 24 hours, the wireless network was attacked and private company information was accessed. Which of the following would be the MOST likely reason for this breach?

- ❍ **A.** Race condition
- ❍ **B.** Jailbreaking
- ❍ **C.** Impersonation
- ❍ **D.** Misconfiguration

Quick Answer: **33**

The Details: **84**

A47. An organization has identified a significant vulnerability in an Internet-facing firewall. The firewall company has stated the firewall is no longer available for sale and there are no plans to create a patch for this vulnerability. Which of the following would BEST describe this issue?

- ❍ **A.** End-of-life
- ❍ **B.** Improper input handling
- ❍ **C.** Improper key management
- ❍ **D.** Incompatible OS

Quick Answer: **33**

The Details: **85**

A48. A company has decided to perform a disaster recovery exercise during an annual meeting with the IT directors and senior directors. A simulated disaster will be presented, and the participants will discuss the logistics and processes required to resolve the disaster. Which of the following would BEST describe this exercise?

- ❍ **A.** Capacity planning
- ❍ **B.** Business impact analysis
- ❍ **C.** Continuity of operations
- ❍ **D.** Tabletop exercise

Quick Answer: **33**

The Details: **86**

A49. A security administrator needs to block users from visiting websites hosting malicious software. Which of the following would be the BEST way to control this access?

- ❍ **A.** Honeynet
- ❍ **B.** Data masking
- ❍ **C.** DNS filtering
- ❍ **D.** Data loss prevention

Quick Answer: **33**

The Details: **87**

A50. A system administrator has been called to a system with a malware infection. As part of the incident response process, the administrator has imaged the operating system to a known-good version. Which of these incident response steps is the administrator following?

- ❍ **A.** Lessons learned
- ❍ **B.** Recovery
- ❍ **C.** Detection
- ❍ **D.** Containment

Quick Answer: **33**

The Details: **88**

A51. A company has placed a SCADA system on a segmented network with limited access from the rest of the corporate network. Which of the following would describe this process?

- ❍ **A.** Load balancing
- ❍ **B.** Least privilege
- ❍ **C.** Data retention
- ❍ **D.** Hardening

Quick Answer: **33**

The Details: **89**

A52. An administrator is viewing the following security log:

```
Dec 30 08:40:03 web01 Failed password for root
from 10.101.88.230 port 26244 ssh2

Dec 30 08:40:05 web01 Failed password for root
from 10.101.88.230 port 26244 ssh2

Dec 30 08:40:09 web01 445 more authentication
failures; rhost=10.101.88.230 user=root
```

Which of the following would describe this attack?

- ❍ **A.** Spraying
- ❍ **B.** Downgrade
- ❍ **C.** Brute force
- ❍ **D.** DDoS

Quick Answer: **33**

The Details: **90**

A53. During a morning login process, a user's laptop was moved to a private VLAN and a series of updates were automatically installed. Which of the following would describe this process?

- ❍ **A.** Account lockout
- ❍ **B.** Configuration enforcement
- ❍ **C.** Decommissioning
- ❍ **D.** Sideloading

Quick Answer: **33**

The Details: **91**

A54. Which of the following describes two-factor authentication?

- ❍ **A.** A printer uses a password and a PIN
- ❍ **B.** The door to a building requires a fingerprint scan
- ❍ **C.** An application requires a pseudo-random code
- ❍ **D.** A Windows Domain requires a password and smart card

Quick Answer: **33**

The Details: **92**

A55. A company is deploying a new application to all employees in the field. Some of the problems associated with this roll out include:

- The company does not have a way to manage the devices in the field
- Team members have many different kinds of mobile devices
- The same device needs to be used for both corporate and private use

Which of the following deployment models would address these concerns?

❍ **A.** CYOD
❍ **B.** SSO
❍ **C.** COPE
❍ **D.** BYOD

Quick Answer: **33**

The Details: **93**

A56. An organization is installing a UPS for their new data center. Which of the following would BEST describe this control type?

❍ **A.** Compensating
❍ **B.** Directive
❍ **C.** Deterrent
❍ **D.** Detective

Quick Answer: **33**

The Details: **94**

A57. A manufacturing company would like to track the progress of parts used on an assembly line. Which of the following technologies would be the BEST choice for this task?

❍ **A.** Secure enclave
❍ **B.** Blockchain
❍ **C.** Hashing
❍ **D.** Asymmetric encryption

Quick Answer: **33**

The Details: **95**

A58. A company's website has been compromised and the website content has been replaced with a political message. Which of the following threat actors would be the MOST likely culprit?

- ❍ **A.** Insider
- ❍ **B.** Organized crime
- ❍ **C.** Shadow IT
- ❍ **D.** Hacktivist

Quick Answer: **33**

The Details: **96**

A59. A Linux administrator is downloading an updated version of her Linux distribution. The download site shows a link to the ISO and a SHA256 hash value. Which of these would describe the use of this hash value?

- ❍ **A.** Verifies that the file was not corrupted during the file transfer
- ❍ **B.** Provides a key for decrypting the ISO after download
- ❍ **C.** Authenticates the site as an official ISO distribution site
- ❍ **D.** Confirms that the file does not contain any malware

Quick Answer: **33**

The Details: **97**

A60. A company's security policy requires that login access should only be available if a person is physically within the same building as the server. Which of the following would be the BEST way to provide this requirement?

- ❍ **A.** USB security key
- ❍ **B.** Biometric scanner
- ❍ **C.** PIN
- ❍ **D.** SMS

Quick Answer: **33**

The Details: **98**

A61. A development team has installed a new application and database to a cloud service. After running a vulnerability scanner on the application instance, a security administrator finds the database is available for anyone to query without providing any authentication. Which of these vulnerabilities is MOST associated with this issue?

- ❍ **A.** Legacy software
- ❍ **B.** Open permissions
- ❍ **C.** Race condition
- ❍ **D.** Malicious update

Quick Answer: **33**

The Details: **99**

A62. Employees of an organization have received an email with a link offering a cash bonus for completing an internal training course. Which of the following would BEST describe this email?

- ❍ **A.** Watering hole attack
- ❍ **B.** Cross-site scripting
- ❍ **C.** Zero-day
- ❍ **D.** Phishing campaign

Quick Answer: **33**

The Details: **100**

A63. Which of the following risk management strategies would include the purchase and installation of an NGFW?

- ❍ **A.** Transfer
- ❍ **B.** Mitigate
- ❍ **C.** Accept
- ❍ **D.** Avoid

Quick Answer: **33**

The Details: **101**

A64. An organization is implementing a security model where all application requests must be validated at a policy enforcement point. Which of the following would BEST describe this model?

- ❍ **A.** Public key infrastructure
- ❍ **B.** Zero trust
- ❍ **C.** Discretionary access control
- ❍ **D.** Federation

Quick Answer: **33**

The Details: **102**

A65. A company is installing a new application in a public cloud. Which of the following determines the assignment of data security in this cloud infrastructure?

- ❍ **A.** Playbook
- ❍ **B.** Audit committee
- ❍ **C.** Responsibility matrix
- ❍ **D.** Right-to-audit clause

Quick Answer: **33**

The Details: **103**

A66. When decommissioning a device, a company documents the type and size of storage drive, the amount of RAM, and any installed adapter cards. Which of the following describes this process?

- ❍ **A.** Destruction
- ❍ **B.** Sanitization
- ❍ **C.** Certification
- ❍ **D.** Enumeration

Quick Answer: **33**

The Details: **104**

A67. An attacker has sent more information than expected in a single API call, and this has allowed the execution of arbitrary code. Which of the following would BEST describe this attack?

- ❍ **A.** Buffer overflow
- ❍ **B.** Replay attack
- ❍ **C.** Cross-site scripting
- ❍ **D.** DDoS

Quick Answer: **33**

The Details: **105**

A68. A company encourages users to encrypt all of their confidential materials on a central server. The organization would like to enable key escrow as a backup option. Which of these keys should the organization place into escrow?

- ❍ **A.** Private
- ❍ **B.** CA
- ❍ **C.** Session
- ❍ **D.** Public

Quick Answer: **33**

The Details: **106**

A69. A company is in the process of configuring and enabling host-based firewalls on all user devices. Which of the following threats is the company addressing?

- ❍ **A.** Default credentials
- ❍ **B.** Vishing
- ❍ **C.** Instant messaging
- ❍ **D.** On-path

Quick Answer: **33**

The Details: **107**

A70. A manufacturing company would like to use an existing router to separate a corporate network from a manufacturing floor. Both networks use the same physical switch, and the company does not want to install any additional hardware. Which of the following would be the BEST choice for this segmentation?

- ❍ **A.** Connect the corporate network and the manufacturing floor with a VPN
- ❍ **B.** Build an air gapped manufacturing floor network
- ❍ **C.** Use host-based firewalls on each device
- ❍ **D.** Create separate VLANs for the corporate network and the manufacturing floor

Quick Answer: **33**

The Details: **108**

A71. An organization needs to provide a remote access solution for a newly deployed cloud-based application. This application is designed to be used by mobile field service technicians. Which of the following would be the best option for this requirement?

- ❍ **A.** RTOS
- ❍ **B.** CRL
- ❍ **C.** Zero-trust
- ❍ **D.** SASE

Quick Answer: **33**

The Details: **109**

A72. A company is implementing a quarterly security awareness campaign. Which of the following would MOST likely be part of this campaign?

- ❍ **A.** Suspicious message reports from users
- ❍ **B.** An itemized statement of work
- ❍ **C.** An IaC configuration file
- ❍ **D.** An acceptable use policy document

Quick Answer: **33**

The Details: **110**

A73. A recent report shows the return of a vulnerability that was previously patched four months ago. After researching this issue, the security team has found a recent patch has reintroduced this vulnerability on the servers. Which of the following should the security administrator implement to prevent this issue from occurring in the future?

- ❍ **A.** Containerization
- ❍ **B.** Data masking
- ❍ **C.** 802.1X
- ❍ **D.** Change management

Quick Answer: **33**

The Details: **111**

A74. A security manager would like to ensure that unique hashes are used with an application login process. Which of the following would be the BEST way to add random data when generating a set of stored password hashes?

- ❍ **A.** Salting
- ❍ **B.** Obfuscation
- ❍ **C.** Key stretching
- ❍ **D.** Digital signature

Quick Answer: **33**

The Details: **112**

A75. Which cryptographic method is used to add trust to a digital certificate?

- ❍ **A.** Steganography
- ❍ **B.** Hash
- ❍ **C.** Symmetric encryption
- ❍ **D.** Digital signature

Quick Answer: **33**

The Details: **113**

A76. A company is using SCAP as part of their security monitoring processes. Which of the following would BEST describe this implementation?

- ❍ **A.** Train the user community to better identify phishing attempts
- ❍ **B.** Present the results of an internal audit to the board
- ❍ **C.** Automate the validation and patching of security issues
- ❍ **D.** Identify and document authorized data center visitors

Quick Answer: **33**

The Details: **114**

A77. An organization maintains a large database of customer information for sales tracking and customer support. Which person in the organization would be responsible for managing the access rights to this data?

- ❍ **A.** Data processor
- ❍ **B.** Data owner
- ❍ **C.** Data subject
- ❍ **D.** Data custodian

Quick Answer: **33**

The Details: **115**

A78. An organization's content management system currently labels files and documents as "Public" and "Restricted." On a recent update, a new classification type of "Private" was added. Which of the following would be the MOST likely reason for this addition?

- ❍ **A.** Minimized attack surface
- ❍ **B.** Simplified categorization
- ❍ **C.** Expanded privacy compliance
- ❍ **D.** Decreased search time

Quick Answer: **33**

The Details: **116**

A79. A corporate security team would like to consolidate and protect the private keys across all of their web servers. Which of these would be the BEST way to securely store these keys?

- ❍ **A.** Integrate an HSM
- ❍ **B.** Implement full disk encryption on the web servers
- ❍ **C.** Use a TPM
- ❍ **D.** Upgrade the web servers to use a UEFI BIOS

Quick Answer: **33**

The Details: **117**

A80. A security technician is reviewing this security log from an IPS:

```
ALERT 2023-06-01 13:07:29 [163bcf65118-179b547b]
Cross-Site Scripting in JSON Data
222.43.112.74:3332 -> 64.235.145.35:80
URL/index.html - Method POST - Query String "-"
User Agent: curl/7.21.3 (i386-redhat-linux-gnu) libcurl/7.21.3
NSS/3.13.1.0 zlib/1.2.5 libidn/1.19 libssh2/1.2.7
Detail: token="<script>" key="key7" value="<script>alert(2)</script>"
```

Which of the following can be determined from this log information? (Select TWO)

- ❍ **A.** The alert was generated from a malformed User Agent header
- ❍ **B.** The alert was generated from an embedded script
- ❍ **C.** The attacker's IP address is 222.43.112.74
- ❍ **D.** The attacker's IP address is 64.235.145.35
- ❍ **E.** The alert was generated due to an invalid client port number

Quick Answer: **33**

The Details: **118**

A81. Which of the following describes a monetary loss if one event occurs?

- ❍ **A.** ALE
- ❍ **B.** SLE
- ❍ **C.** RTO
- ❍ **D.** ARO

Quick Answer: **33**

The Details: **119**

A82. A user with restricted access has typed this text in a search field of an internal web-based application:

```
USER77' OR '1'='1
```

After submitting this search request, all database records are displayed on the screen. Which of the following would BEST describe this search?

- ❍ **A.** Cross-site scripting
- ❍ **B.** Buffer overflow
- ❍ **C.** SQL injection
- ❍ **D.** SSL stripping

Quick Answer: **33**

The Details: **120**

A83. A user has opened a helpdesk ticket complaining of poor system performance, excessive pop up messages, and the cursor moving without anyone touching the mouse. This issue began after they opened a spreadsheet from a vendor containing part numbers and pricing information. Which of the following is MOST likely the cause of this user's issues?

- ❍ **A.** On-path
- ❍ **B.** Worm
- ❍ **C.** Trojan horse
- ❍ **D.** Logic bomb

Quick Answer: **33**

The Details: **121**

A84. A web-based manufacturing company processes monthly charges to credit card information saved in the customer's profile. All of the customer information is encrypted and protected with additional authentication factors. Which of the following would be the justification for these security controls?

- ❍ **A.** Chain of custody
- ❍ **B.** Password vaulting
- ❍ **C.** Compliance reporting
- ❍ **D.** Sandboxing

Quick Answer: **33**

The Details: **122**

A85. A security manager has created a report showing intermittent network communication from certain workstations on the internal network to one external IP address. These traffic patterns occur at random times during the day. Which of the following would be the MOST likely reason for these traffic patterns?

- ❍ **A.** On-path attack
- ❍ **B.** Keylogger
- ❍ **C.** Replay attack
- ❍ **D.** Brute force

Quick Answer: **33**

The Details: **123**

A86. The security policies in a manufacturing company prohibit the transmission of customer information. However, a security administrator has received an alert that credit card numbers were transmitted as an email attachment. Which of the following was the MOST likely source of this alert message?

- ❍ **A.** IPS
- ❍ **B.** DLP
- ❍ **C.** RADIUS
- ❍ **D.** IPsec

Quick Answer: **33**

The Details: **124**

A87. A security administrator has configured a virtual machine in a screened subnet with a guest login account and no password. Which of the following would be the MOST likely reason for this configuration?

- ❍ **A.** The server is a honeypot for attracting potential attackers
- ❍ **B.** The server is a cloud storage service for remote users
- ❍ **C.** The server will be used as a VPN concentrator
- ❍ **D.** The server is a development sandbox for third-party programming projects

Quick Answer: **33**

The Details: **125**

A88. A security administrator is configuring a DNS server with a SPF record. Which of the following would be the reason for this configuration?

- ❍ **A.** Transmit all outgoing email over an encrypted tunnel
- ❍ **B.** List all servers authorized to send emails
- ❍ **C.** Digitally sign all outgoing email messages
- ❍ **D.** Obtain disposition instructions for emails marked as spam

Quick Answer: **33**

The Details: **126**

A89. A company would like to securely deploy applications without the overhead of installing a virtual machine for each system. Which of the following would be the BEST way to deploy these applications?

- ❍ **A.** Containerization
- ❍ **B.** IoT
- ❍ **C.** Proxy
- ❍ **D.** RTOS

Quick Answer: **33**

The Details: **127**

A90. A company has just purchased a new application server, and the security director wants to determine if the system is secure. The system is currently installed in a test environment and will not be available to users until the roll out to production next week. Which of the following would be the BEST way to determine if any part of the system can be exploited?

- ❍ **A.** Tabletop exercise
- ❍ **B.** Vulnerability scanner
- ❍ **C.** DDoS
- ❍ **D.** Penetration test

Quick Answer: **33**

The Details: **128**

Practice Exam A
Multiple Choice Quick Answers

A6. B
A7. C
A8. A
A9. A
A10. C
A11. C
A12. A
A13. D
A14. A, E, and G
A15. B
A16. C
A17. A
A18. A
A19. A
A20. C
A21. B
A22. C
A23. B and D
A24. B
A25. C
A26. B
A27. A
A28. B
A29. C
A30. D
A31. D
A32. A
A33. B
A34. D
A35. A
A36. D
A37. D
A38. D
A39. D
A40. C
A41. C
A42. A
A43. B
A44. D
A45. C
A46. D
A47. A
A48. D
A49. C
A50. B
A51. D
A52. C
A53. B
A54. D
A55. C
A56. A
A57. B
A58. D
A59. A
A60. B
A61. B
A62. D
A63. B
A64. B
A65. C
A66. D
A67. A
A68. A
A69. C
A70. D
A71. D
A72. A
A73. D
A74. A
A75. D
A76. C
A77. D
A78. C
A79. A
A80. B and C
A81. B
A82. C
A83. C
A84. C
A85. B
A86. B
A87. A
A88. B
A89. A
A90. D

Practice Exam A
Detailed Answers

A1. Match the description with the most accurate attack type.
Not all attack types will be used.



Attacker obtains bank account number
and birth date by calling the victim



Vishing

Social engineering over the telephone continues to be an effective attack vector, and obtaining personal information such as a bank account or birth date would be considered phishing over voice, or vishing.



More information:
SY0-701, Objective 2.2 - Phishing
https://professormesser.link/701020202



Attacker accesses a database directly
from a web browser



Injection

A SQL (Structured Query Language) injection attack sends SQL commands directly to a database using a vulnerable web application.



More information:
SY0-701, Objective 2.3 - SQL Injection
https://professormesser.link/701020306



Attacker intercepts all communication between
a client and a web server



On-path

On-path attacks are quite effective because the attacker can often sit invisibly between two devices and gather useful information or modify the data streams in real-time.



More information:
SY0-701, Objective 2.4 - On-path Attacks
https://professormesser.link/701020409



Multiple attackers
overwhelm a web server



DDoS

A DoS (Denial of Service) occurs when a service is unavailable due to the actions of a third-party. A DDoS (Distributed Denial of Service) occurs when multiple third-parties work together to create a service outage.

More information:
SY0-701, Objective 2.4 - Denial of Service
https://professormesser.link/701020406



Attacker obtains a list of all login credentials used
over the last 24 hours



Keylogger

Attackers can install hardware or software keyloggers to capture all information typed into a keyboard. Keylogger software can also capture screenshots and other media and covertly send all of this information to the attacker using an existing Internet connection.

More information:
SY0-701, Objective 2.4 - Other Malware Types
https://professormesser.link/701020404

A2. The security team at a manufacturing company is creating a set of security standards for employees and visitors.

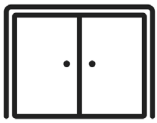
Select the BEST security control for each location.
All of the available security controls will be used once.

Outside Building	Parking and Visitor drop-off		Fencing Lighting

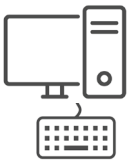
Security outside of the building is focused on the safety of employees and visitors as they park their vehicles or are dropped off at the entrance. The parking lot and exterior building areas should be surrounded by fencing to control access and the parking lot should be well-lit at all times.

Reception	Building lobby		Security guard Access control vestibule

The reception area is the first interaction with employees or visitors. Security guards should be available to check the authorization of anyone entering the building, and the use of an access control vestibule can help manage the flow of individuals through this checkpoint.

Data Center Door	Entrance from inside building		Access badge Biometrics

Once inside, many areas of the building are readily available to employees and visitors. However, some areas of the building containing sensitive information may require additional authorization. To gain access to the data center from inside of the building, an individual would need to provide a valid access badge and perform a biometric check of their fingerprint, handprint, or a similar type of authentication factor.

Server Administration	Authentication to server console in the data center		Authentication token

Gaining access through the door of the data center doesn't provide any access to the server data. If a technician needs console access to a server, they'll need to provide the proper username, password, and authentication token. This multi-factor authentication ensures only authorized users are able to gain access to the information contained on the server.

More information:
SY0-701, Objective 1.2 - Physical Security
https://professormesser.link/701010206

A3. Select the most appropriate security category.
Some categories may be used more than once.

Operational	A guard checks the identification of all visitors
Managerial	All returns must be approved by a Vice President
Physical	A generator is used during a power outage
Physical	Building doors can be unlocked with an access card
Technical	System logs are transferred automatically to a SIEM

Control categories describe the type of security applied to a task or event.

Operational controls are often implemented by people instead of systems. Security guards and awareness programs are examples of an operational control.

Managerial controls are administrative controls associated with security design and implementation. A set of policies and procedures would be an example of a managerial control.

Physical controls are used to limit physical access. Badge readers, fences, and guard shacks are categorized as physical controls.

Technical controls are implemented using systems. Operating system controls, firewalls, and automated processes are considered technical controls.



More information:
SY0-701, Objective 1.1 - Security Controls
https://professormesser.link/701010101

A4. Match the appropriate authentication factor to each description. Each authentication factor will be used once.

Something you know | Something you have | Something you are | Somewhere you are

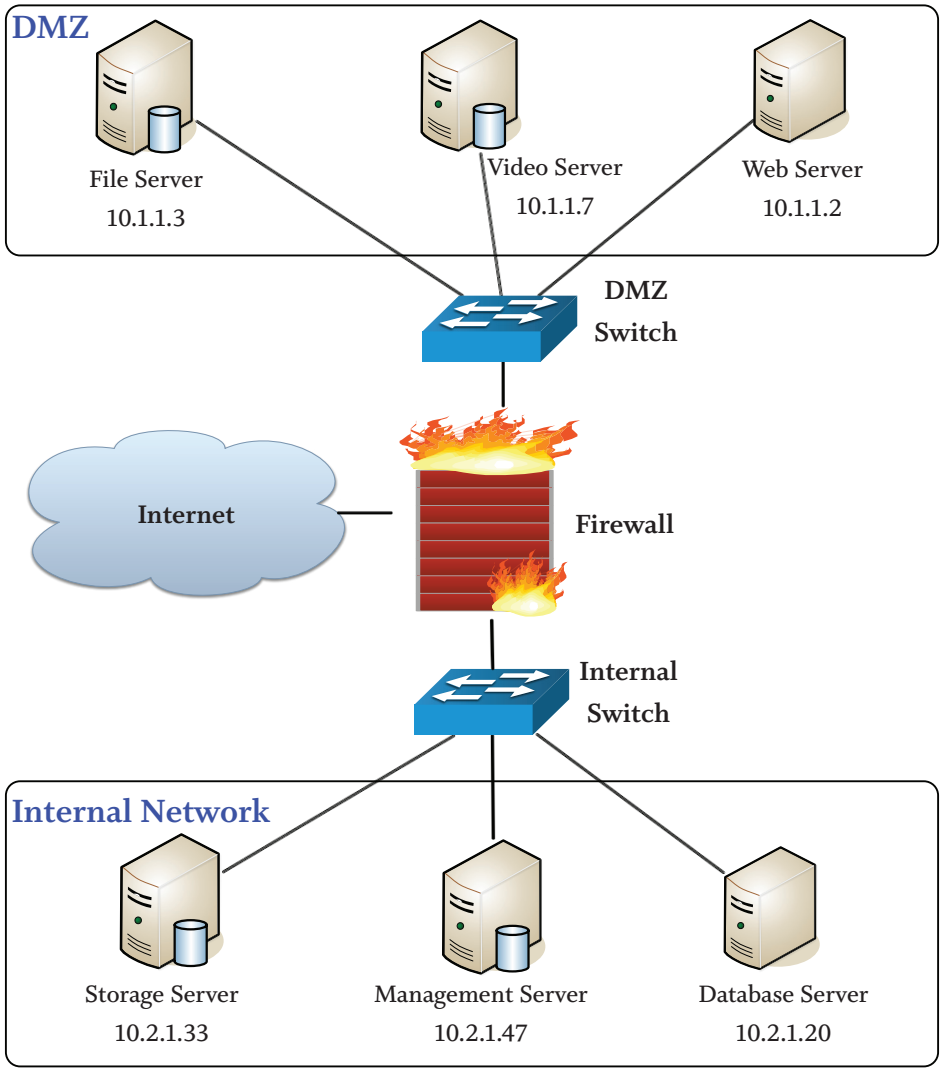
Description	Authentication Factor
During the login process, your phone receives a text message with a one-time passcode	Something you have
You enter your PIN to make a deposit into an ATM	Something you know
You can use your fingerprint to unlock the door to the data center	Something you are
Your login will not work unless you are connected to the VPN	Somewhere you are

Authentication factors are important to consider when developing applications or designing network infrastructures. It's useful to know each authentication factor and some examples of how that factor can be applied during the authentication process.

More information:
SY0-701, Objective 4.6 - Multi-factor Authentication
https://professormesser.link/701040603

A5. Configure the following stateful firewall rules:

- Block HTTP sessions between the Web Server and the Database Server
- Allow the Storage Server to transfer files to the Video Server over HTTPS
- Allow the Management Server to use a secure terminal on the File Server



Rule #	Source IP	Destination IP	Protocol (TCP/UDP)	Port #	Allow/ Block
1	10.1.1.2	10.2.1.20	TCP	80	Block
2	10.2.1.33	10.1.1.7	TCP	443	Allow
3	10.2.1.47	10.1.1.3	TCP	22	Allow